

Детектируем атаку Certighost

 purpleshift.io/ru/articles/2026-08-07-certighost

5 августа 2026 г.

```
python3 krbrelayx.py -t 'http://braavos.essos.local/certsrv/certfnsh.asp' --adcs --template Machine -v 'BRAAVOS$'
[*] Protocol Client SMB loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Running in attack mode to single host
[*] Running in kerberos relay mode because no credentials were specified.
[*] Setting up SMB Server
[*] Setting up HTTP Server on port 80
[*] Setting up DNS Server
[*] Servers started, waiting for connections
[*] SMBD: Received connection from 192.168.9.172
[*] HTTP server returned status code 200, treating as a successful login
[*] Using template name: Machine
[*] Generating CSR...
[*] CSR generated!
[*] Getting certificate...
[*] GOT CERTIFICATE! ID 12
[*] Writing PKCS#12 certificate to ./BRAAVOS.pfx
[*] Certificate successfully written to file
```

1. [Статьи](#)/

Сегодня поговорим об относительно свежей уязвимости в Active Directory Certificate Services, которая заключается в эксплуатации резервного механизма ADCS. При его использовании Certification Authority обращается к указанному контроллеру домена (атрибут cdc) для получения информации о машинном объекте, связанным с запросом (атрибут rmd). А уязвимость Certighost (CVE-2026-54121) состоит в том, что СА не проверяет, действительно ли в cdc указан настоящий контроллер домена.

Поэтому атакующий может указать подконтрольный ему хост с поддельными службами LDAP/LSA для ответа на запрос. В итоге пользователь с минимальными правами может получить контроль над доменом. Подробнее об уязвимости и работе механизма можно почитать в [оригинальном исследовании](#) и в описании протокола [MS-WCCE](#).

Как это обнаружить

После успешного запуска [PoC](#), помимо очевидных хантов на имя созданной компьютерной учётной записи и на артефакты, унаследованные от Certipy и Impacket, сразу возникает желание искать характерный набор атрибутов запроса: SAN с DNS-именем, cdc и rmd.

```

[*] Connecting to LDAPS
[*] Detecting infrastructure
    DC: 192.168.56.12 | CA: ESSOS-CA (192.168.56.23)
    Target: MEEREEN$ | SID: S-1-5-21-666199682-1411342147-2938717855-1001
[*] Creating computer: GHOSTTREGQLVF$
[*] Starting rogue servers (LSA:445 + LDAP:389)
[*] Requesting certificate (template=Machine, cdc=192.168.9.167)
    Saved: meereen.pfx
[*] PKINIT as MEEREEN$
[*] Got hash for MEEREEN$:
    MEEREEN$:aad3b435b51404eeaad3b435b51404ee:cd5108e350b4bcbef2c7c22e0dacd68d
    ccache: meereen.ccache
[*] GGWP

```

```

Certificate Services received a certificate request.

Request ID:      11
Requester:      ESSOS\GHOSTTREGQLVF$
Attributes:     CertificateTemplate:Machine
SAN:dns=GHOSTTREGQLVF.essos.local
cdc:192.168.9.167
rmd:meereen.essos.local

```

Однако строить детектирование исключительно на одновременном присутствии всех трёх атрибутов небезопасно. DNS-имя в CSR может быть передано несколькими способами:

- как дополнительный атрибут SAN:dns=..., передаваемый в структуре pwszAttributes,
- в X.509 расширении Subject Alternative Name.

Как правило, значение из pwszAttributes считается более приоритетным.

Если мы изучим код предложенного POC, то обнаружим, что SAN передается и [в специальном расширении](#) и в атрибутах. Можем убрать его из pwszAttributes и успешно повторить атаку. В этом случае наш теоретический хант на список атрибутов не сработает.

Пример события 4887 - успешно выданного сертификата, который бы не попал под планируемый хант:

```

Certificate Services approved a certificate request and issued a certificate.

Request ID:      14
Requester:      ESSOS\GHOSTCTESWMSOS
Attributes:     CertificateTemplate:Machine
cdc:192.168.9.167
rmd:meereen.essos.local
Disposition:    3
SKI:            f7 f8 3d b8 c0 7b 07 4f 21 c8 d0 2b 8a 30 74 f5 a6 85 7b 78
Subject:        CN=meereen.essos.local

```

Правильнее будет ориентироваться только на параметр `cdc`. Если в нём IP-адрес или не имя одного из известных вам контроллеров домена, то скорее всего этот запрос связан с эксплуатацией уязвимости.

У выделенного сервера Certification Authority набор легитимных исходящих сетевых соединений обычно невелик и хорошо поддаётся инвентаризации. Поэтому соединение CA с неизвестным или неразрешённым хостом само по себе необычно.

Одним из наиболее универсальных способов обнаружения этой атаки будет мониторинг исходящих соединений процесса `certsrv.exe` (либо всего CA-сервера, если процессная телеметрия недоступна) к адресам, не входящим в заранее определённый список разрешённых узлов.

Для обнаружения Certighost в первую очередь следует контролировать исходящие соединения на TCP-порты 445 и 389. Через SMB на порту 445 CA обращается к удалённой LSA-службе, а через LDAP на порту 389 получает сведения об объекте каталога. Порт 636 также можно включить в правило для более общего контроля LDAP(S). В правильно сегментированной сети подобное соединение в принципе не должно устанавливаться: исходящий SMB и LDAP трафик от CA следует разрешать только к известным контроллерам домена и другим явно необходимым системам.

Если всё же исходящие сетевые соединения не ограничены, то можно использовать эту уязвимость и в качестве соерсе. Указав подконтрольный хост в атрибуте `cdc`, атакующий может заставить CA инициировать SMB-подключение и аутентифицироваться от имени учётной записи компьютера CA-сервера.

```
└─$ python3 krbrelayx.py -t 'http://braavos.essos.local/certsrv/certfnsh.asp' --adcs --template Machine -v 'BRAAVOS$'
[*] Protocol Client SMB loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Running in attack mode to single host
[*] Running in kerberos relay mode because no credentials were specified.
[*] Setting up SMB Server
[*] Setting up HTTP Server on port 80
[*] Setting up DNS Server
[*] Servers started, waiting for connections
[*] SMBD: Received connection from 192.168.9.172
[*] HTTP server returned status code 200, treating as a successful login
[*] Using template name: Machine
[*] Generating CSR ...
[*] CSR generated!
[*] Getting certificate...
[*] GOT CERTIFICATE! ID 12
[*] Writing PKCS#12 certificate to ./BRAAVOS.pfx
[*] Certificate successfully written to file
```

Меры защиты

Для устранения уязвимости в первую очередь необходимо установить соответствующее [обновление безопасности](#) на все ADCS-сервера.

В качестве дополнительной меры защиты рекомендуется ограничить исходящий сетевой трафик с ADCS-серверов, разрешив только соединения, необходимые для их работы. В частности, обращения по SMB и LDAP должны быть разрешены только к известным контроллерам домена и другим заранее определённым хостам.

Если немедленно установить обновление невозможно, исследователи предлагают временно отключить fallback-механизм, удалив из параметра `EditFlags` флаг `EDITF_ENABLECHASECLIENTDC`. Однако важно понимать, что это лишь временная мера, а не замена обновлению. Кроме того, после отключения механизма перестанут работать легитимные сценарии регистрации сертификатов, которые зависят от `cdc`.